



Cybersecurity Risk Assessment Framework

A practical, structured approach to identifying threats, evaluating vulnerabilities, and strengthening defenses — built specifically for Small and Medium Enterprises.

NIST FRAMEWORK

SME SECURITY

RISK MANAGEMENT



Why SMEs Are Prime Targets

Cybercriminals see small businesses as low-hanging fruit — limited budgets, fewer IT resources, and low security awareness create exploitable gaps that attackers actively seek out.

Limited Budgets

Security is often deprioritized in favor of core operations.

Thin IT Teams

Many SMEs lack dedicated security staff or expertise.

Awareness Gaps

Employees are rarely trained to recognize cyber threats.

The Threat Landscape Facing SMEs

Six attack vectors account for the majority of small business breaches — each carrying serious financial and operational consequences.



Phishing

Deceptive emails tricking users into revealing credentials.



Ransomware

Encrypts data and demands payment for release.



Malware

Malicious software designed to damage or infiltrate systems.



Insider Threats

Employees or contractors misusing authorized access.



Password Attacks

Brute-force and credential-stuffing exploits weak logins.



Data Breaches

Unauthorized access to sensitive customer or business data.

What This Framework Sets Out to Do

01

Identify Critical Assets

Map the systems, data, and infrastructure that drive business operations.

02

Discover Threats & Vulnerabilities

Pinpoint where the organization is exposed and how attackers could exploit it.

03

Assess & Prioritize Risks

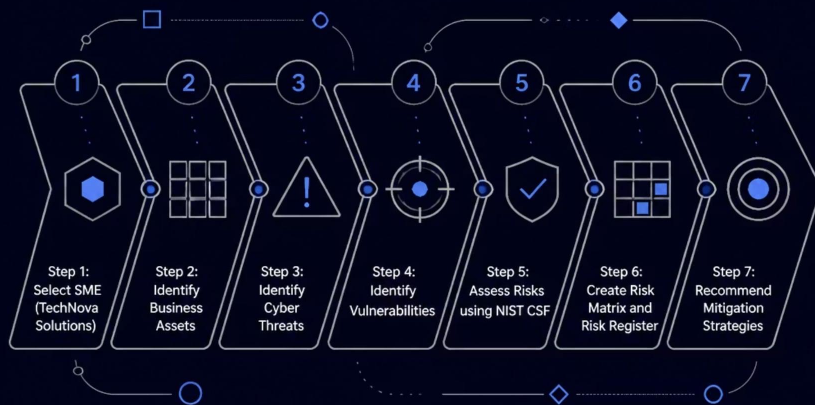
Evaluate each risk by likelihood and impact to focus resources where they matter most.

04

Recommend Security Controls

Propose practical, cost-effective measures to strengthen the overall security posture.

Seven-Step Assessment Workflow



Grounded in NIST

Every step aligns with the **NIST Cybersecurity Framework** – the global gold standard for managing cyber risk. The methodology is repeatable, scalable, and designed for SMEs with limited resources.

☐ This framework can be applied to any organization, regardless of industry or size.

CASE STUDY

TechNova Solutions Pvt. Ltd.



Company Snapshot

A fictional IT services firm based in **Mumbai** with **50 employees** across HR, Finance, IT, Sales, and Management.

IT Infrastructure

- Windows laptops & on-premise servers
- Microsoft 365 cloud productivity suite
- VPN & next-gen firewall
- Customer database & backup server
- Office Wi-Fi network

What We're Protecting

Every asset represents a potential entry point for attackers. Knowing what you have is the first step to defending it.



Employee Laptops

Primary endpoints for daily work and data access.



Windows Servers

Host critical applications and internal services.



Customer Database

Contains sensitive client information requiring strict protection.



Email System

Key vector for phishing and business email compromise.



Firewall & VPN

Perimeter defenses controlling network access.



Office Wi-Fi

Wireless network requiring strong encryption and access controls.



Backup Server

Last line of defense for data recovery after an incident.

Where the Gaps Are

Common Weaknesses Found

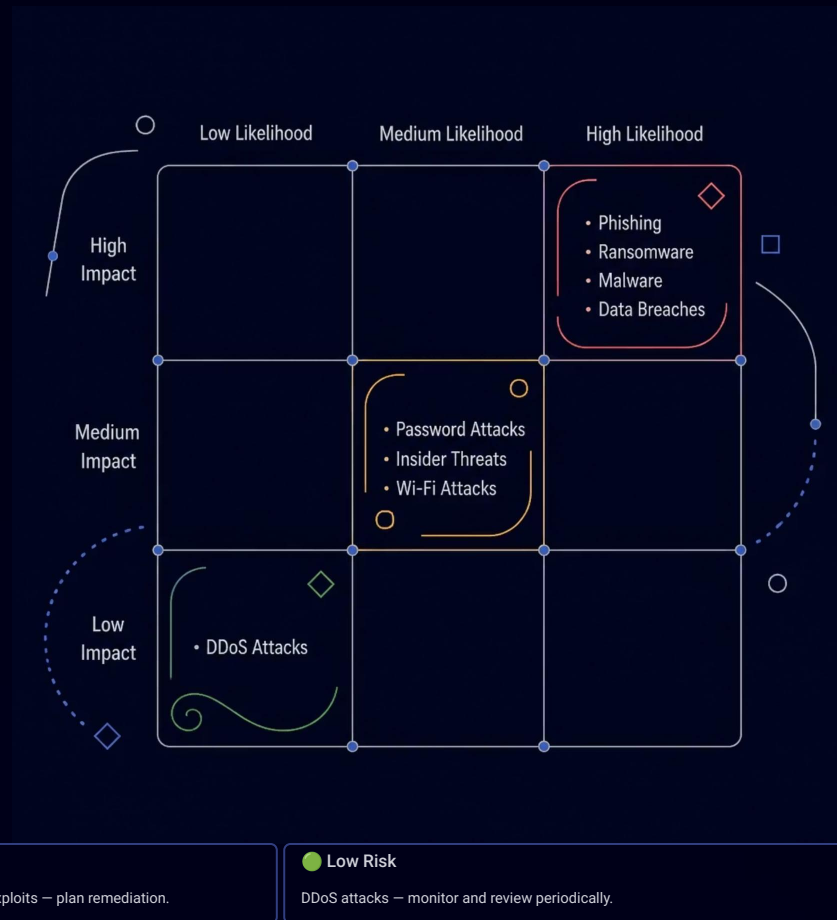
Vulnerabilities are the cracks attackers exploit. At TechNova, seven critical gaps were identified across people, processes, and technology.

- **Weak passwords** — no complexity enforcement
- **No Multi-Factor Authentication (MFA)**
- **Outdated software** — missing critical patches
- **Lack of employee security awareness**
- **Excessive user privileges** — over-permissioned accounts
- **Poor patch management** processes
- **Weak Wi-Fi security** configuration



Risk = Likelihood × Impact

Each threat is scored on a 1–5 scale for likelihood and impact. The product determines overall risk level and drives prioritization.



Strengthening TechNova's Security Posture



MFA & Strong Passwords

Enforce multi-factor authentication and complex password policies.



Security Awareness Training

Regular training to reduce human error and phishing susceptibility.



Patch Management & EDR

Automate updates and deploy Endpoint Detection & Response.



RBAC & Network Controls

Least-privilege access, hardened firewall, and encrypted VPN.

✓ This structured assessment identified critical risks and proposed targeted controls – significantly strengthening TechNova's security posture. Regular reassessment keeps defenses current.

References

- NIST Cybersecurity Framework (CSF) & SP 800-53
- OWASP Top 10
- CISA Cybersecurity Best Practices
- ISO/IEC 27001